OSINT
FOR HACKERS

Reconnaissance, Exposure, and Defense

PASSIVE COLLECTION · ATTACK-SURFACE MAPPING · INVESTIGATOR TRADECRAFT

AGENDA

What We'll Cover

01 OSINT fundamentals & methodology

02 Search-engine and document recon

03 Domain, DNS & infrastructure mapping

04 People, email & social-media recon

05 Image, archive & physical OSINT

06 Tooling, investigator OPSEC & reporting

What OSINT Is

The collection and analysis of publicly accessible information — websites, search engines, social media, domain records, certificate logs, public documents, job posts, paste sites, and archives.

KEY RULE

If obtaining the information requires authentication, exploitation, or circumventing a control, it is no longer OSINT.

PRE-ENGAGEMENT RECON IDENTIFIES

1. Domains, subdomains, IP ranges & exposed services
2. Employees, email formats & social profiles
3. Technology stack & forgotten subdomains
4. Physical locations & organizational relationships
5. Publicly leaked data enabling social engineering

A Repeatable Five-Step Model

01 — Define

Set the intelligence requirement — what question is being answered

→

02 — Scope

Org, domains, IP ranges, geography, time window, authorization

→

03 — Collect

Passive DNS, certs, search engines, repos, social media, archives

→

04 — Validate

Cross-verify across independent sources; assign a confidence level

→

05 — Report

Attack-surface map, evidence, risk rating, remediation

Google Dork Operators

Advanced search operators surface pages and files ordinary queries miss — exposed documents, login portals, and misconfigured directories.

Operator	Purpose	Example
`site:`	Restrict results to a domain	`site:example.com`
`inurl:`	Search URL text	`inurl:admin`
`intitle:`	Search page title	`intitle:"index of"`
`filetype: / ext:`	Search file type	`filetype:pdf`
`"..."`	Exact phrase match	`"internal use only"`
`-`	Exclude a term	`site:example.com -www`
`cache:`	Cached/historical view	`cache:example.com`

Document & Image Metadata

Public PDFs, Word files, spreadsheets, and images routinely carry hidden metadata that expands the picture of a target's people and infrastructure.

- Author names & usernames
- Email addresses
- Internal network names
- Internal file paths
- Software versions & revision history
- GPS geolocation in images

EXTRACTION

```
exiftool report.pdf
```

```
exiftool image.jpg
```

```
exiftool -a -u -g1 document.docx
```

Metadata can be stale or misleading — treat it as a lead, not a conclusion, and corroborate before reporting.

Domain & DNS Discovery

Mapping the external attack surface begins with ownership records and the DNS layer.

DISCOVERY SOURCES

1. WHOIS / RDAP records
2. Reverse WHOIS
3. Certificate Transparency logs
4. DNS records (A, MX, NS, TXT)
5. ASN ownership
6. Acquisition & brand research

EXAMPLE WORKFLOW

```
whois example.com

dig example.com ANY

dig example.com MX

dig example.com NS

dig example.com TXT

host example.com
```

RDAP: https://rdap.org/domain/example.com

Subdomain Enumeration

PASSIVE

Certificate transparency, public DNS datasets, search engines, archives, third-party data.

```
curl -s "https://crt.sh/?q=%25.example.com&output=json" |
jq -r '.[].name_value'
amass enum -passive -d example.com
subfinder -d example.com -silent
```

ACTIVE

DNS brute forcing, permutation generation, HTTP probing — interacts with the target, authorization required.

```
dnsx -l subdomains.txt -silent
httpx -l live-hosts.txt -title -tech-detect -status-code
```

HIGH-VALUE PATTERNS TO FLAG

- dev / test / staging / uat / demo
- vpn / mail / remote / portal / admin / api
- Forgotten cloud-hosted applications
- Dangling CNAMEs → subdomain takeover
- Domains resolving to default pages
- Expired or misconfigured DNS entries

Shodan & Censys

Internet-wide scanning engines reveal what services an organization exposes — open ports, banners, certificates, device metadata.

GreyNoise adds internet-background-noise context to separate targeted scanning from mass internet traffic.

EXAMPLE QUERIES

```
org:"Example Corp"
ssl.cert.subject.CN:"example.com"
hostname:"example.com"
http.title:"Dashboard"
product:"nginx"
port:3389
port:22
```

Technology & Historical Data

FINGERPRINTING

BuiltWith / Wappalyzer — tech stack detection

HISTORICAL

Wayback Machine — removed pages, old infra

SecurityTrails / passive DNS — historical records

CODE EXPOSURE

```
"example.com" filename:.env

"example.com" "AWS_ACCESS_KEY_ID"

"example.com" "smtp_password"

org:example-org filename:config
```

People & Email Discovery

HUMAN-FOCUSED OSINT SUPPORTS

- Phishing simulations
- Social-engineering assessments
- Insider-risk analysis
- Executive protection

SOURCES

- LinkedIn & company websites
- theHarvester
- Hunter.io
- Have I Been Pwned (breach awareness)
- Public PDFs & conference lists

EMAIL-FORMAT PERMUTATIONS

```
john.doe@example.com
jdoe@example.com
j.doe@example.com
doej@example.com
john_doe@example.com
```

Username & Social-Media Correlation

Usernames often link a person across platforms. A single match is weak evidence — corroborate with profile details, photos, writing style, links, and employer.

CORRELATION TOOLS

Sherlock

Maigret

WhatsMyName

Maltego

SOCIAL COLLECTION TARGETS

- Names, roles & reporting structure
- Job postings revealing technologies
- Conference talks & presentation slides
- Photos of badges, offices, whiteboards
- Posts revealing travel or projects

Beyond the Screen

1 Image OSINT

EXIF metadata & GPS coordinates

Device model & timestamp

Reflections, signage, landmarks

`Reverse image search (Lens, TinEye, Yandex)`

2 Web Archives

Deleted pages & old portals

Former employee directories

Historical product documentation

`web.archive.org/web/*/example.com/*`

3 Physical & Geo

Street View & satellite imagery

Public business listings & reviews

Event pages & job-posting locations

`Geo-tagged social photos`

Essential OSINT Tools

Each tool answers a specific question — not a substitute for the methodology.

Category	Tools	Question Answered
Domains	`Amass, Subfinder, theHarvester, crt.sh`	*What external assets exist?*
Infrastructure	`Shodan, Censys, GreyNoise`	*What services & devices are exposed?*
Relationship mapping	`Maltego, SpiderFoot, Recon-ng`	*How do entities connect?*
People / usernames	`Sherlock, Maigret, WhatsMyName`	*Where does this identity appear?*
Email / breaches	`Hunter.io, Have I Been Pwned, holehe`	*What contact & exposure indicators exist?*
Images	`ExifTool, Google Lens, TinEye`	*What metadata or visual context exists?*
Archives	`Wayback Machine, archive.today`	*What existed previously?*

OPSEC Workflow

A structured process for protecting the investigator's identity, client, and findings during collection.

1. **Identify what to protect**
   Identity, client, purpose, tooling
2. **Identify observers**
   Target, platform, third parties
3. **Identify exposure points**
   IP address, browser fingerprint, account linkage
4. **Apply controls**
   Isolation, VPN/Tor, separate identities, minimal footprint
5. **Validate controls**
   Confirm isolation before each session
6. **Review & improve**
   Post-engagement retrospective

Reporting Structure

1. Engagement details
2. Executive summary
3. Intelligence requirements
4. Findings (evidence, confidence, impact)
5. Attack-surface map
6. Risk matrix
7. Recommendations
8. Appendix (commands, screenshots, sources)

Key Takeaways

OSINT is structured analysis, not just running tools — value comes from validated, correlated, actionable intelligence.

Attackers use OSINT to build an attack path; defenders use the same techniques to shrink their exposure.

A single search result is not proof — validate ownership, recency, source reliability, and context.

OSINT ends where authentication, exploitation, or unauthorized access begins.